

ResolvX

Change Management Policy

Topic-Specific Policy - Change Control for Production Systems

POL-013 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-013
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	VP Engineering
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.32, A8.31 · NIST CSF 2.0 PR.PS-06, PR.IR-03 · SOC 2 CC8.1

1. Purpose

This Change Management Policy establishes how changes to ResolvX's production systems, infrastructure, and application code are proposed, reviewed, approved, and deployed.

A disciplined change process protects the availability and integrity commitments ResolvX makes to its clients. As most production incidents originate from a change, not from an external attack, so controlling how changes reach production is one of the highest-value controls in the engineering organisation. This policy formalises the environment separation and peer-review discipline ResolvX already practises, and defines the approval, testing, and rollback standards that govern every production change going forward.

2. Scope

This policy applies to any change to:

- Production application code and configuration.
- Production cloud infrastructure (AWS resources, network configuration, IAM policies).
- Infrastructure-as-code and CI/CD pipeline configuration.
- Database schema and production data migrations.

Changes confined to development or an individual's personal sandbox environment are not in scope. Security patches follow this policy's approval and testing structure but are governed by the SLA timelines in POL-010, not this policy's standard change lead times.

3. Change Categories

Category	Definition	Approval Required
Standard	Pre-approved, low-risk, repeatable change with a documented, tested procedure (e.g., routine dependency bump, config value already validated in staging).	Peer code review only
Normal	Any change not pre-approved as Standard and not an emergency which are the majority of production changes.	Peer code review + passing CI/CD checks; High-blast-radius changes additionally require VP Engineering sign-off.
Emergency	Change required immediately to remediate an active incident or Critical security finding.	Expedited path per §6, CISO or VP Engineering verbal/written approval, formal review after the fact.

"High blast radius" means a change affecting production database schema, authentication/authorization logic, IAM permissions, or any change to a system classified Critical under POL-008's Business Impact Analysis.

4. Standard Change Path

Every Normal or Standard change follows the same environment path: development, then staging, then production. Which is consistent with the environment separation ResolvX already maintains (ISO A8.31):

- Change is developed and tested in a development environment.
- Change is opened as a pull request; automated CI/CD checks (tests, Snyk scanning) must pass before review.
- At least one peer review approval is required before merge, where the author of a change does not approve their own pull request.
- Change is validated in staging before a production deployment is triggered.
- Production deployment occurs through the CI/CD pipeline; direct production access to make an untracked change is not a valid deployment path.

5. Change Freeze Periods

Non-critical Normal changes are held during defined freeze windows, to avoid introducing new risk while ResolvX's ability to respond is already reduced:

- During an active P1 or P2 incident under the Incident Response Plan, until the incident is resolved or the CISO explicitly authorises unrelated changes to continue.
- During a declared BCP/DR activation under POL-008, until recovery is confirmed.
- Emergency changes (§6) are exempt from freeze periods by definition.

6. Emergency Change Process

An emergency change follows an expedited approval path rather than skipping approval entirely:

- VP Engineering or the CISO gives verbal or written approval before deployment, based on the urgency of the incident or finding being addressed.
- The change is still deployed through the CI/CD pipeline wherever technically possible, even under time pressure — a direct, untracked production change remains a last resort, not a default.
- A full peer review is completed within 2 business days after deployment, and any issue found is remediated immediately.
- Emergency changes related to an actively exploited Critical vulnerability follow POL-010 §6.2's same-day path; this section governs the change-control side of that same event.

7. Rollback & Post-Change Verification

Every Normal and Emergency change has an identified rollback path, a previous known-good deployment, a feature flag, or a reverse migration, confirmed before deployment begins, not improvised after something breaks.

- The change author monitors relevant Datadog dashboards and error rates for a minimum of 30 minutes following a production deployment, or longer for a High-blast-radius change.
- A change that triggers a Critical or High severity monitoring alert within the post-deployment observation window is rolled back by default unless VP Engineering explicitly decides to proceed.

8. Change Log & Audit Trail

GitHub's pull request history, combined with CI/CD deployment logs, serves as the change log for this policy so a separate manually maintained log is not required. Every production deployment is traceable to a specific pull request, its reviewer, and its CI/CD run.

9. Roles & Responsibilities

9.1 VP Engineering

- Owns this policy and the change management process.
- Approves High-blast-radius Normal changes and post-deployment rollback decisions (§7).
- Reviews the change management log quarterly, per the existing controls register review cadence.

9.2 DevSecOps

- Maintains CI/CD pipeline checks (automated tests, Snyk scanning) that gate every change.

9.3 All Engineering Personnel

- Follow the standard change path (§4) for every production change; do not self-approve pull requests.
- Monitor post-deployment as required under §7.

10. Compliance and Enforcement

A production change deployed without required peer review, or a direct untracked production change made outside the CI/CD pipeline without a declared emergency, is treated as a control deficiency and logged in the Corrective Action Plan. Repeated bypass of this policy is addressed under POL-002's disciplinary process.

11. Document Control

Policy ID	POL-013
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	VP Engineering
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.32, A8.31 · NIST CSF 2.0 PR.PS-06, PR.IR-03 · SOC 2 TSC CC8.1
Related Documents	POL-002 (Acceptable Use Policy), POL-007 (Logging & Monitoring Policy), POL-008 (BCP/DR Policy & Plan), POL-010 (Patch Management Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		